



VIET NAM NATIONAL UNIVERSITY HO CHI MINH CITY
INTERNATIONAL UNIVERSITY

System and Network Security

Introduction

Le Hai Duong, PhD. (lhduong@hcmiu.edu.vn)

Materials

- **Textbook:**

- [Du2017] Du, W. (2017). *Computer Security: a hands-on approach*. CreateSpace.
- [Stallings2018] Stallings, W., Brown, L. (2018). *Computer security: principles and practice* (4th ed.). Upper Saddle River, NJ, USA: Pearson Education.

- **Other useful books:**

- [Chapple2021] Chapple, M. (2021). *CISSP Official Study Guide* (9th ed.). Sybex.
- [Walker2019] Walker, M. (2019). *CEH Certified Ethical Hacker All-in-One Exam Guide* (4th ed.). McGraw-Hill Education.
- [Fox2014] Fox, R. (2014). *Linux with operating system concepts*. CRC Press.
- [Nemeth2018] Nemeth, E., Snyder, G., Hein, T. R., Whaley, B., & Mackin, D. (2018). *UNIX and Linux system administration handbook* (5th ed.). Addison-Wesley.

Tentative Schedule

Session	Title
	SECURITY OVERVIEW
1	- Overview of computer concepts and foundations; threats, attacks, and assets - Setup Lab on your PC - Unix/Linux security basics
	COMPUTER SECURITY TECHNOLOGY AND PRINCIPLE
2	- User Identification and Authentication
3	- Access control
	APPLIED CRYPTOGRAPHY
4	- Secret key encryption
5	- Oneway hash function
6	- Public key cryptography
7	- Public key infrastructure - Transport layer security
MIDTERM	

	WEB SECURITY
8	- Same Origin Policy - Cross-site request forgery attack (CSRF)
9	- Cross-site scripting attack (XSS)
10	- SQL-inject attack
11	- Click-jacking attack - Web tracking
	NETWORK SECURITY
12	- Network basics, NAT - Packet sniffing and spoofing - MAC layer attack
13	- UDP protocol attack - TCP protocol attack
14	- Virtual private network (VPN) - Firewall, IDS & IPS
15	Review
FINAL	

Gradings

- Labs, homeworks, quizzes 30%
- Midterm exam 30%
- Final exam 40%

Outline

- Cybersecurity and Information Security
- Security Attacks
- Security Services
- Security Mechanisms
- Security Evaluation

Three fundamental questions

- What assets do need to protect?
- How are those assets threatened?
- What can we do to counter those threats?

Cybersecurity and Information Security

Cybersecurity

- Protect stored, transmitted, and processed information in
 - networked systems
 - digital devices
 - network devices and transmission lines

Information Security

- Ensure **confidentiality**, **integrity** and **availability** of information
—> CIA Triad
- Ensure **authenticity**, **accountability**, **nonrepudiation**, and **reliability**

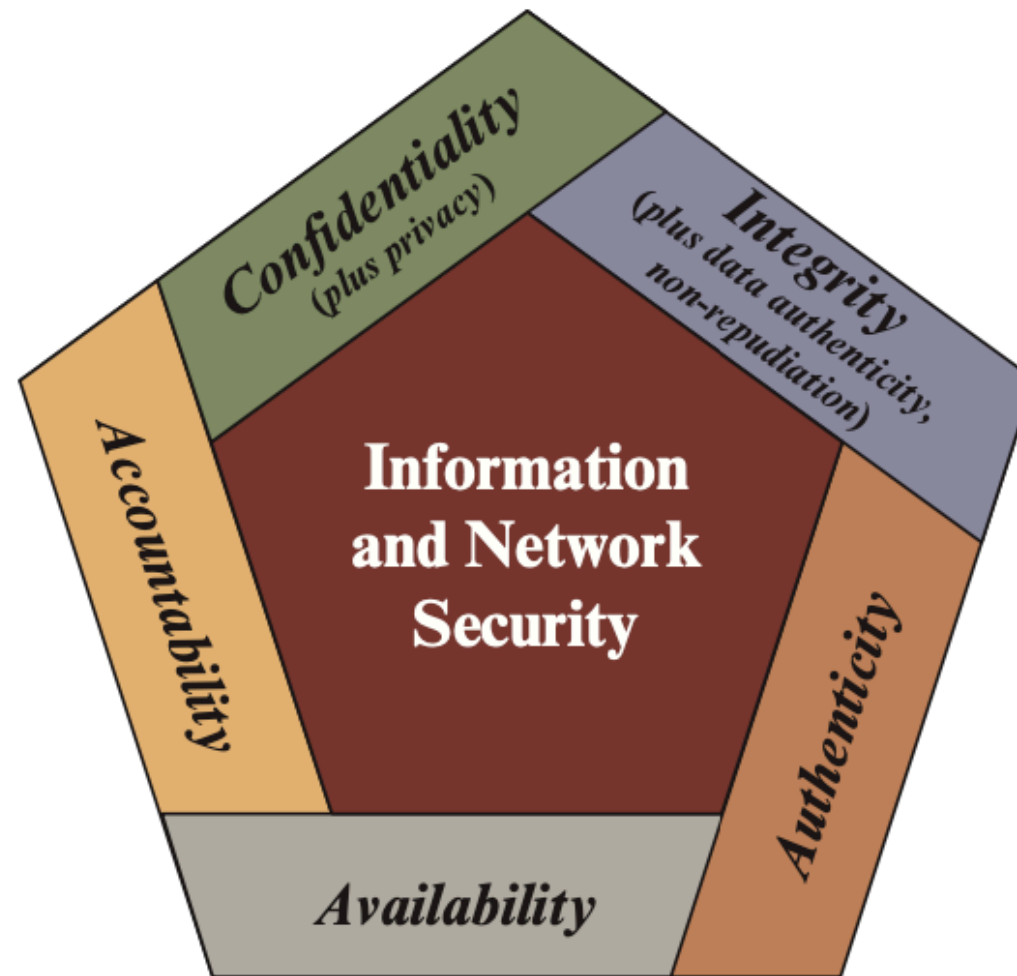


Figure 1.1 Essential Information and Network Security Objectives

“Measures and controls that ensure confidentiality, integrity, and availability of information system assets including hardware, software, firmware, and information being processed, stored, and communicated.”

The NIST Internal/Interagency Report NISTIR 7298 (*Glossary of Key Information Security Terms* , May 2013) defines the term **computer security**

CIA Triad

Primary goals and objectives of a security infrastructure

- **Confidentiality:** Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. A loss of confidentiality is the unauthorized disclosure of information.
 - Data confidentiality
 - Privacy
- **Integrity:** Guarding against improper information modification or destruction, including ensuring information nonrepudiation and authenticity. A loss of integrity is the unauthorized modification or destruction of information.
 - Data integrity
 - System integrity
- **Availability:** Ensuring timely and reliable access to and use of information. A loss of availability is the disruption of access to or use of information or an information system.

DAD Triad

Failures of security protections in the CIA Triad

- **Disclosure** occurs when sensitive or **confidential** material is accessed by unauthorized entities, it is a violation of confidentiality
- **Alternation** occurs when data is either maliciously or accidentally changed, it is a violation of **integrity**.
- **Destruction** occurs when a resource is damaged or made inaccessible to authorized users (technically we usually call the later denial of service (DoS)), it is a violation of **availability**.

.

AAA services

Core security mechanism of all security environments

Five processes of security:

- **Identification** is claiming to be an identity when attempting to access a secured area or system.
- **Authentication** is proving that you are that claimed identity.
- **Authorization** is defining the permissions (i.e., allow/grant and/or deny) of a resource and object access for a specific identity or subject.
- **Auditing** is recording a log of the events and activities related to the system and subjects.
- **Accounting** (aka *accountability*) is reviewing log files to check for compliance and violations in order to hold subjects accountable for their actions, especially violations of organizational security policy.

Security Attacks

Vulnerabilities, Threats and Attacks

- A **vulnerability** is simply a weakness that can be exploited by an attacker to perform unauthorized actions within a computer or network system.
 - corrupted (loss of integrity)
 - leaky (loss of confidentiality)
 - unavailable or very slow (loss of availability)
- **Threats**
 - capable of exploiting vulnerabilities
 - represent potential security harm to an asset
- **Attacks** (threats carried out)
 - **Passive** – attempt to learn or make use of information from the system that does not affect system resources
 - **Active** – attempt to alter system resources or affect their operation
 - **Insider** – initiated by an entity inside the security parameter
 - **Outsider** – initiated from outside the perimeter

Countermeasures

- Means used to deal with security attacks
 - Prevent
 - Detect
 - Recover
- Goal is to minimize residual level of risk to the assets
- May itself introduce new vulnerabilities
- Residual vulnerabilities may remain

Passive vs Active Attacks

Network security attacks can be classified as passive attacks and active attacks

- **Passive:** Attempts to learn or make use of information from the system but does not affect system resources
 - Eavesdropping on, or monitoring of, transmissions
 - Goal of attacker is to obtain information that is being transmitted
 - Two types:
 - Release of message contents
 - Traffic analysis
- **Active:** Attempts to alter system resources or affect their operation
 - Involve some modification of the data stream or the creation of a false stream
 - Four categories:
 - Replay
 - Masquerade
 - Modification of messages
 - Denial of Service

Types of Attacks

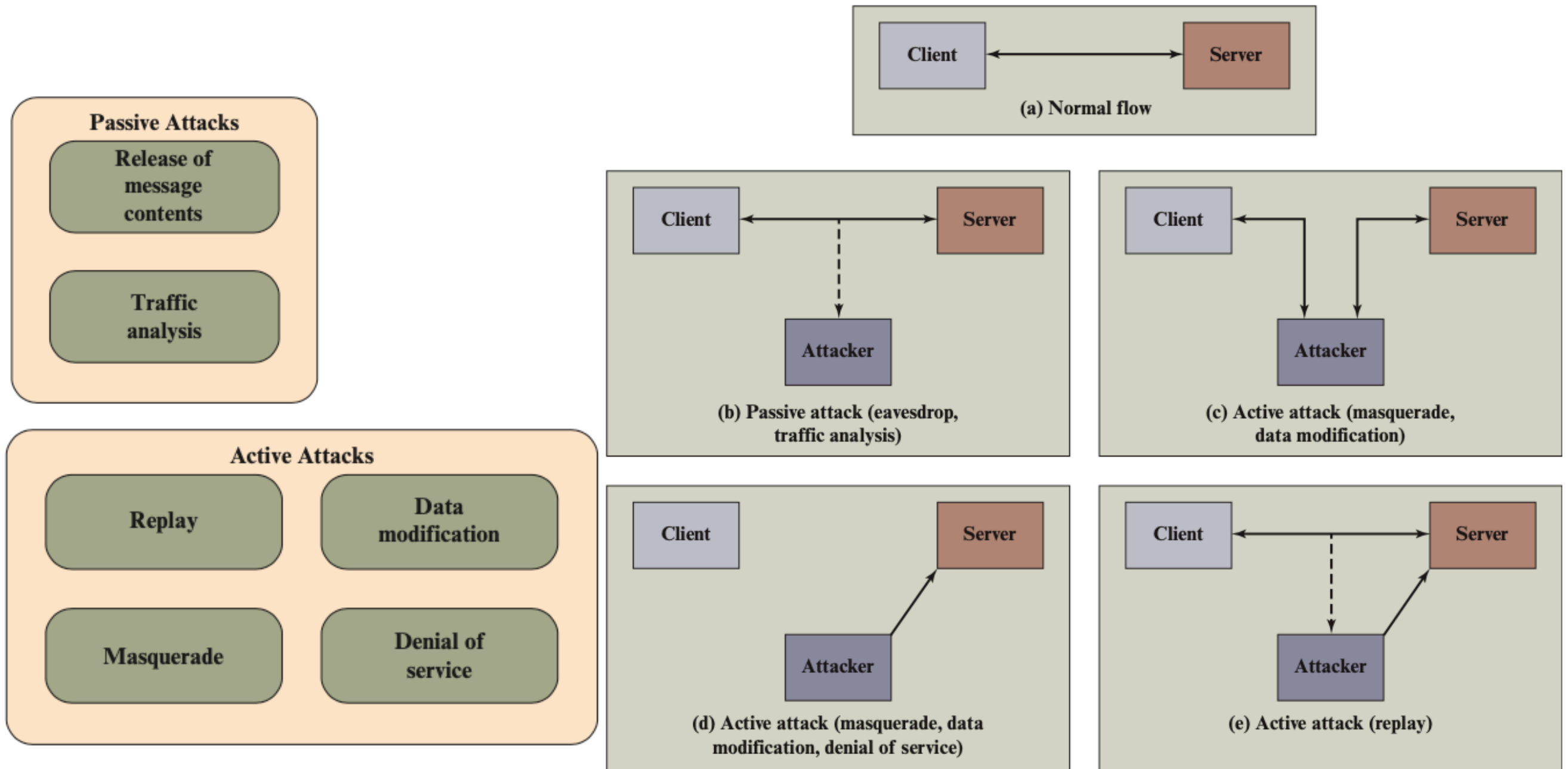
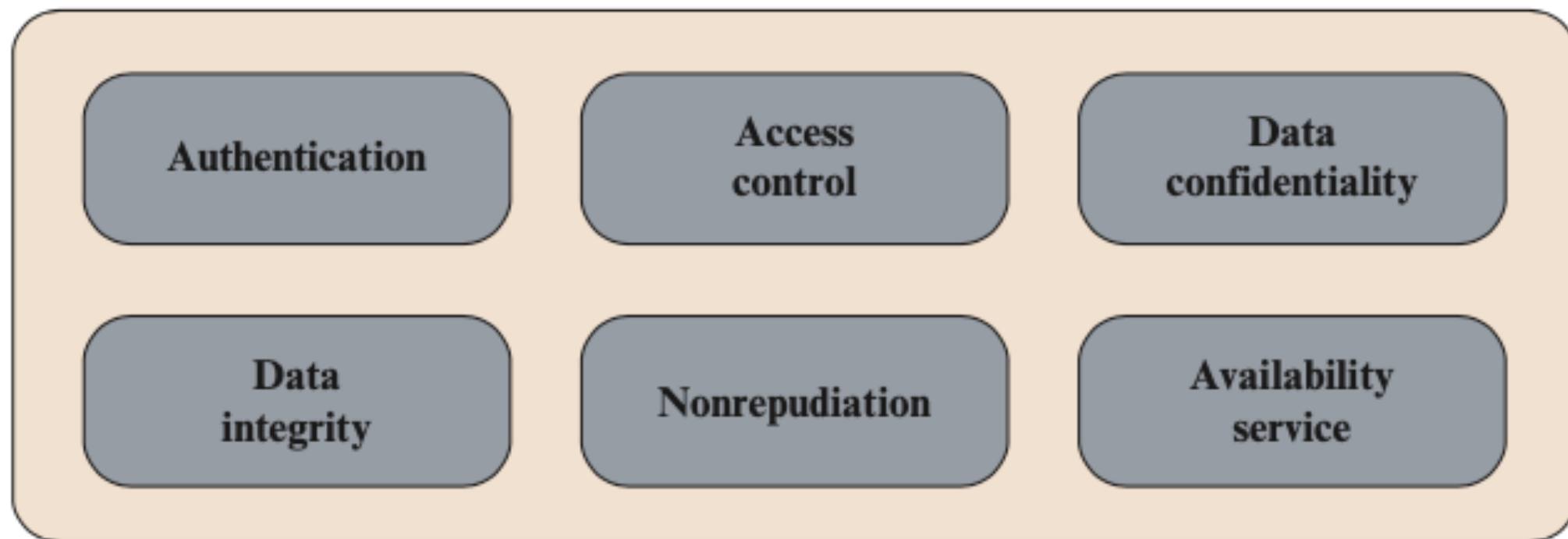


Figure 1.3 Security Attacks

Security Services

Security Services

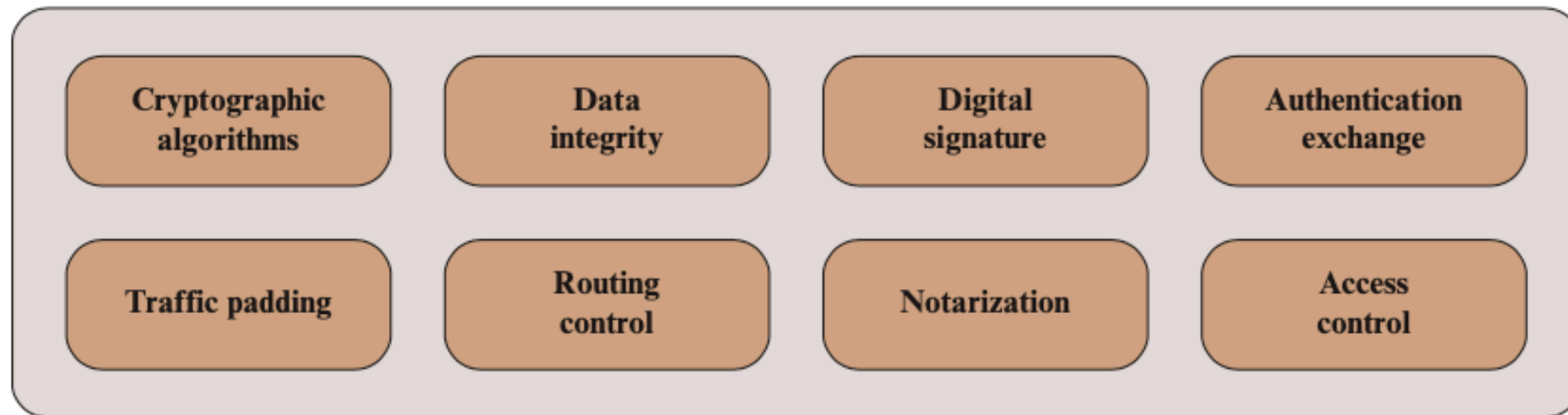


(b) Services

- **Authentication:** ensure a communication is authentic
 - Peer entity authentication
 - Data origin authentication
- **Access control:** ability to limit and control the access to host systems and applications via communications links
- **Data confidentiality:** protection of transmitted data from passive attacks
- **Data integrity:** make sure that received data are not altered
- **Nonrepudiation:** prevents either sender or receiver from denying a transmitted messages
- **Availability service:** protects a system to ensure its availability

Security Mechanisms

Security Mechanisms



(c) Mechanisms

- A process (or a device incorporating such a process) that can be **used in a system to implement a security service** that is provided by or within the system

Security Evaluation

Evaluating and classifying threats

Attack Surface

- An **attack surface** consists of the **reachable and exploitable vulnerabilities** in a system
 - Open ports on outward facing Web and other servers, and code listening on those ports
 - Services available on the inside of a firewall
 - Code that processes incoming data, e-mail, XML, office documents, and industry-specific custom data exchange formats
 - Interfaces, SQL, and web forms
 - An employee with access to sensitive information vulnerable to a social engineering attack

Attack surface analysis

- Useful technique for assessing the scale and severity of threats to a system.
- A systematic analysis of points of vulnerability makes developers and security analysts aware of where security mechanisms are required.
- Find ways to make the surface smaller, thus making the task of the adversary more difficult.
- Provides guidance on setting priorities for testing, strengthening security measures, or modifying the service or application.

.

Attack surface categories

- Network attack surface
- Software attack surface
- Human attack surface

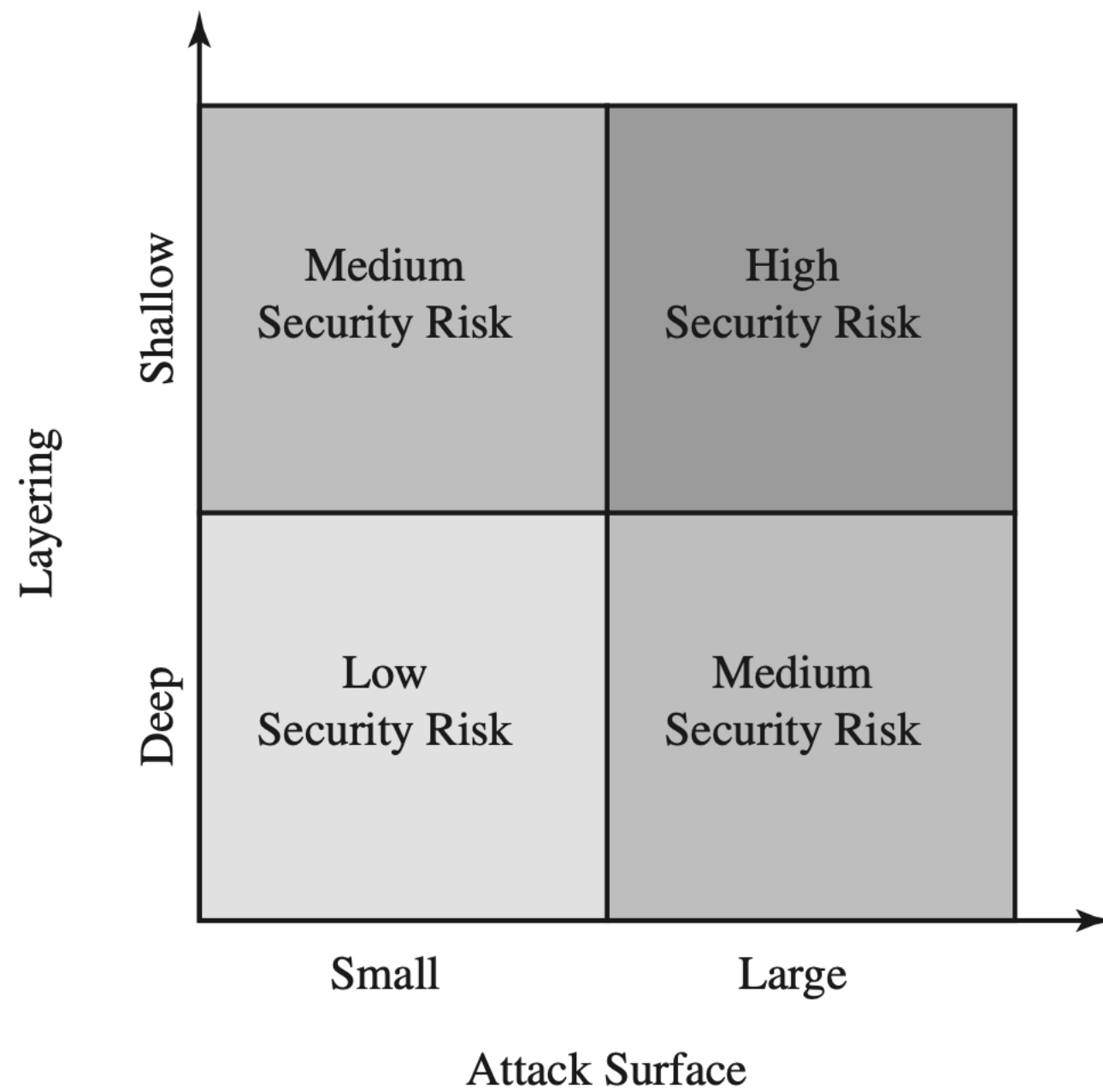


Figure 1.4 Defense in Depth and Attack Surface

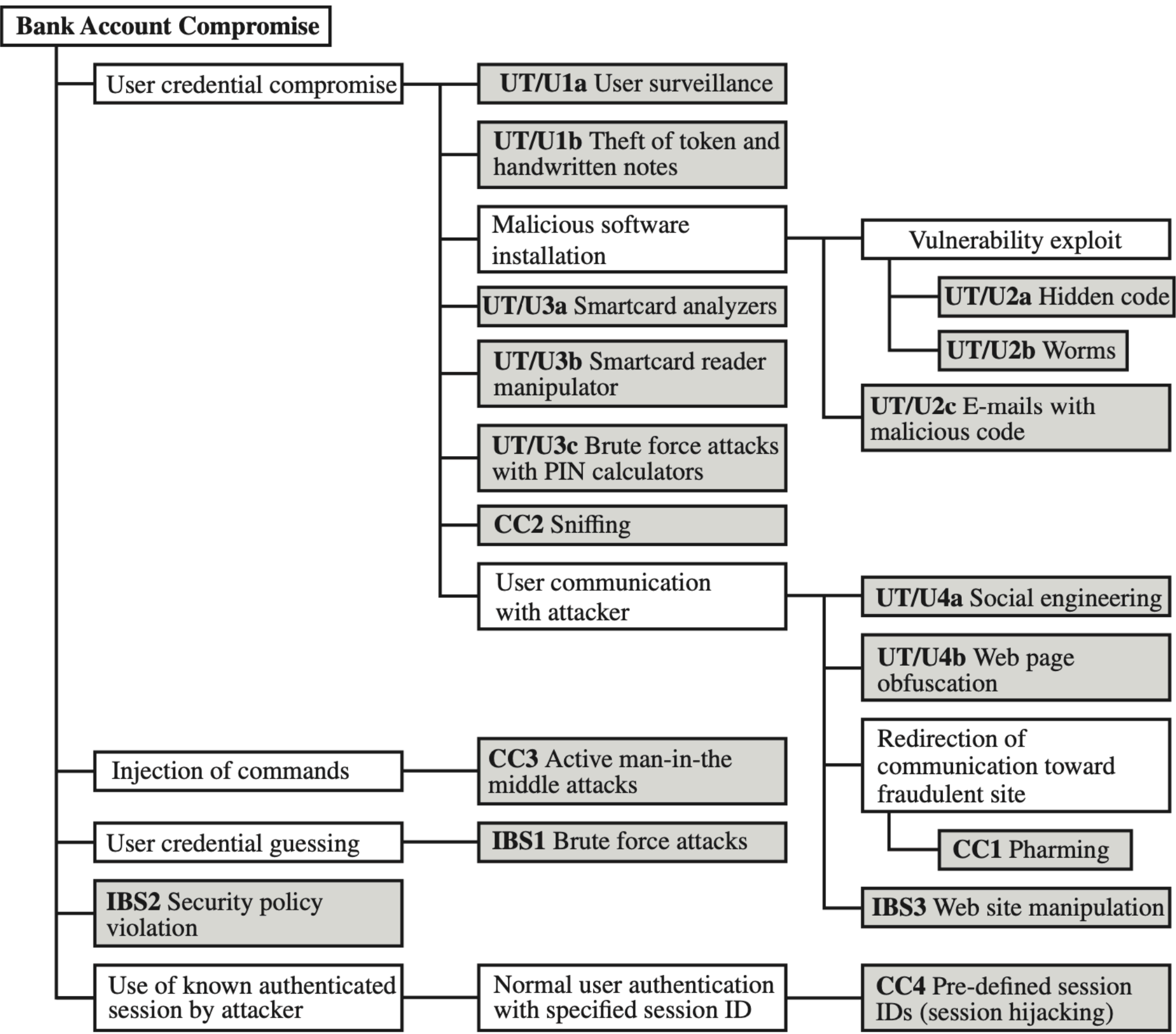
Evaluating and classifying threats

Attack Trees

- An attack tree is a branching, hierarchical data structure that represents a **set of potential techniques for exploiting security vulnerabilities**.
 - security incident that is the goal of the attack is represented as the **root node** of the tree
 - the ways by which an attacker could reach that goal are iteratively and incrementally represented as **branches** and **subnodes** of the tree
 - each subnode defines a subgoal
 - **leaf nodes**, represent different ways to initiate an attack

Attack trees

- The use of attack trees is to effectively exploit the information available on attack patterns.
- Security analysts can use the attack tree to document security attacks in a structured form that reveals key vulnerabilities.
- The attack tree can guide both the design of systems and applications, and the choice and strength of countermeasures.



- **User terminal and user (UT/U):**
These attacks target the user equipment, including the tokens that may be involved, such as smartcards or other password generators, as well as the actions of the user.
- **Communications channel (CC):**
This type of attack focuses on communication links.
- **Internet banking server (IBS):**
These types of attacks are offline attack against the servers that host the Internet banking application.

Figure 1.5 An Attack Tree for Internet Banking Authentication

Who is who?

- Many of the security techniques and applications in this course have been specified as standards. Standards have been developed to cover management practices and the overall architecture of security mechanisms and services. The most important of these organizations are:
 - National Institute of Standards and Technology (NIST)
 - NIST is a U.S. federal agency that deals with measurement science, standards, and technology related to U.S. government use and to the promotion of U.S. private sector innovation.
 - Despite its national scope, NIST Federal Information Processing Standards (**FIPS**) and Special Publications (SP) have a worldwide impact.
 - Internet Society (ISOC)
 - ISOC is a professional membership society that provides leadership in addressing issues that confront the future of the Internet, and is the organization home for the groups responsible for Internet infrastructure standards (**RFC**).
 - International Telecommunication Union (ITU-T)
 - ITU is a United Nations agency in which governments and the private sector coordinate global telecom networks and services. ITU-T standards are referred to as Recommendations.
 - International Organization for Standardization (ISO)
 - ISO is a nongovernmental organization whose work results in international agreements that are published as International Standards

Reading

- Chapter 1 of [Stallings2018]